

AWS WAF Security Intelligence & Observability Platform

Project Documentation | Generated 2026-06-25

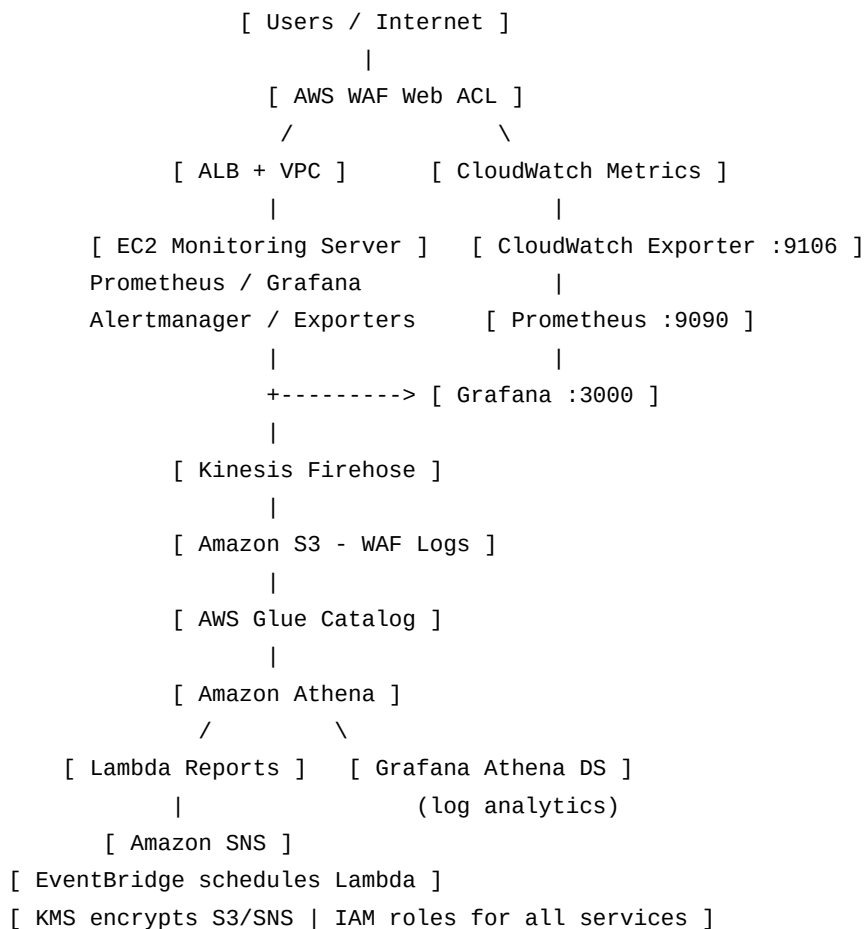
Enterprise-grade AWS WAF monitoring, analytics, reporting, and observability for single-account sandbox deployments. This document covers architecture, AWS services, data flows, Prometheus monitoring, Grafana dashboards, and tests.

1. Executive Summary

The platform protects web applications with AWS WAF, streams security logs to S3, analyzes threats with Glue and Athena, delivers scheduled reports via Lambda and SNS, and provides real-time observability through Prometheus, Grafana, and Alertmanager on EC2.

2. AWS Architecture Overview

Open `diagrams/aws-architecture.drawio` in `diagrams.net` for the full visual diagram with official AWS service icons. The ASCII overview below matches that layout.

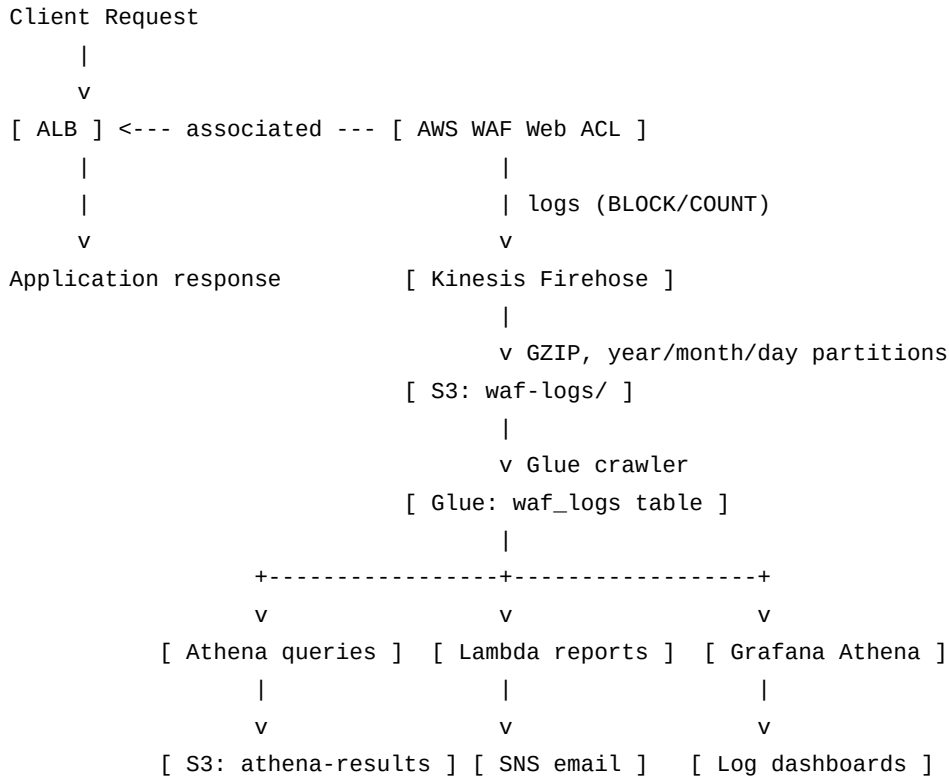


3. AWS Services and Importance

- AWS WAF: First line of defense. Blocks SQLi, XSS, bad inputs, bots, rate abuse.
- Application Load Balancer: Distributes HTTP traffic; WAF is associated with the ALB.
- Amazon VPC: Network isolation. Public subnets host ALB and monitoring EC2 instances.
- Kinesis Firehose: Reliable, buffered delivery of WAF logs to S3 with partitioning.
- Amazon S3: Durable log storage (`waf-logs/`), reports, and Athena query results.

- AWS Glue: Catalog and crawler for waf_logs table used by Athena and Grafana.
- Amazon Athena: Serverless SQL on logs for reports, forensics, and Grafana panels.
- AWS Lambda: Scheduled report generator (HTML/CSV) triggered by EventBridge.
- Amazon EventBridge: Cron schedules for daily, weekly, and monthly reports.
- Amazon SNS: Email notifications for reports and security/platform alerts.
- Amazon CloudWatch: WAF/Firehose/Lambda/ALB metrics, alarms, and dashboards.
- Amazon EC2: Hosts Prometheus, Grafana, Alertmanager, and exporters (4 instances).
- AWS KMS: Encrypts S3 objects, SNS topics, Firehose logs, and Athena results.
- AWS IAM: Least-privilege roles for Firehose, Lambda, Glue, WAF logging, and EC2.

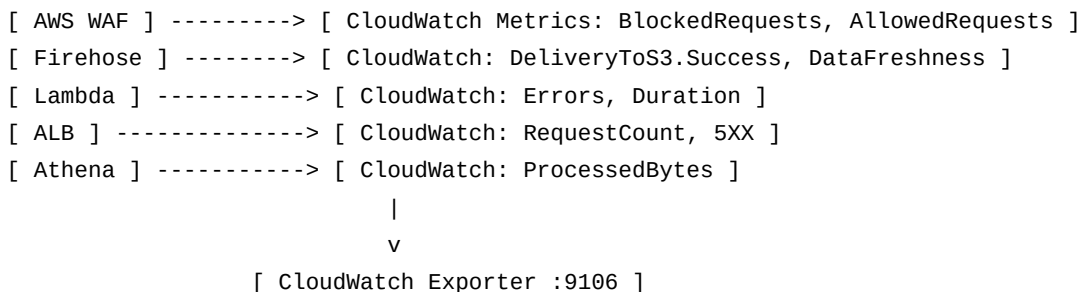
4. Data Flow (Log Pipeline)

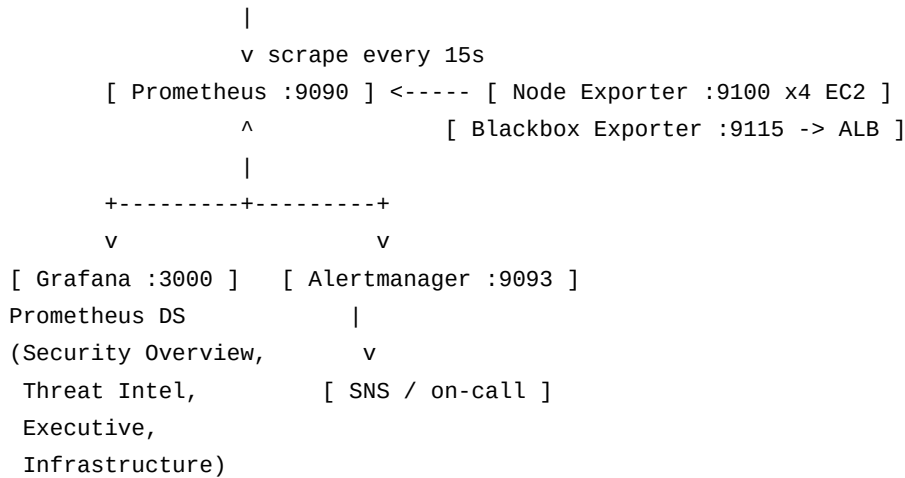


Log pipeline steps: (1) WAF evaluates request, (2) log record sent to Firehose, (3) Firehose writes to S3, (4) Glue crawler updates partitions, (5) Athena/Grafana/Lambda query logs.

5. Metrics Flow (Prometheus-Centric)

Prometheus is the central metrics store on the monitoring EC2. CloudWatch Exporter pulls AWS metrics; Node Exporter and Blackbox Exporter provide infra and ALB health data.





6. Prometheus Monitoring (Detailed)

6.1 Scrape Targets

Job	Target / Purpose
prometheus	localhost:9090 - Self-monitoring
node-exporter	agent EC2s :9100 - CPU, memory, disk, network
node-exporter-monitoring	localhost:9100 - Monitoring server health
cloudwatch-exporter	localhost:9106 - AWS WAF, Firehose, Lambda, ALB, Athena metric
blackbox-exporter	ALB DNS via :9115 - HTTP probe_success for ALB health
aws-waf-cloudwatch	filtered aws_wafv2_* - WAF-specific metric relabeling
aws-firehose-cloudwatch	filtered aws_firehose_* - Delivery pipeline health
aws-lambda-cloudwatch	filtered aws_lambda_* - Report generator errors
aws-athena-cloudwatch	filtered aws_athena_* - Query volume monitoring

6.2 Key Prometheus Metrics

- aws_wafv2_blocked_requests_sum - blocked requests by rule
- aws_wafv2_allowed_requests_sum - allowed requests by rule
- aws_firehose_delivery_to_s3_success_average - log delivery health
- aws_lambda_errors_sum - report Lambda failures
- node_cpu_seconds_total - infrastructure CPU
- node_memory_MemAvailable_bytes - memory pressure
- probe_success{job=blackbox-alb} - ALB reachability
- up - scrape target availability

6.3 Alert Rules (waf-alerts.yml)

Alert	Severity / Condition
HighBlockRate	critical: Block rate > 10/s for 5m
SQLiSurge	high: SQLi blocks elevated
XSSSurge	high: XSS/BadInputs blocks elevated
BotAttackSurge	medium: Bot control blocks elevated
TopAttackerSpike	high: Sudden coordinated attack pattern
HighCPUUsage	medium: Node CPU > 85% for 10m
HighMemoryUsage	medium: Memory > 90% for 10m
DiskSpaceLow	high: Disk < 15% free

LambdaErrors	high: Report generator failing
FirehoseDeliveryFailures	critical: S3 delivery < 95%
PrometheusTargetDown	critical: Scrape target unreachable
BlackboxProbeFailure	high: ALB health probe failed

6.4 Storage and Retention

- TSDB retention: 30 days (prometheus.yml)
- Scrape interval: 15 seconds
- Rule evaluation interval: 15 seconds

7. Grafana Dashboards

Dashboard	Datasource / Purpose
WAF Security Overview	Prometheus: Block/allow rates, SQLi/XSS/Bot, node CPU, ALB pro
Threat Intelligence	Prometheus: Attack trends by rule type
Executive Dashboard	Prometheus: Block rate %, platform health summary
Infrastructure Monitoring	Prometheus: CPU, memory, disk, Firehose, scrape targets
WAF Log Analytics (Athena)	Athena: Top attackers, countries, URIs, recent blocks

8. Reporting and Alerting Flow

```
[ EventBridge cron ]
|  daily 06:00 UTC | weekly Mon 07:00 | monthly 1st 08:00
v
[ Lambda Report Generator ]
|-- runs 6 Athena queries (top_attackers, countries, sqli, xss, bot, summary)
|-- builds HTML + CSV
v
[ S3: reports/ ] + [ SNS notification email ]

[ Prometheus alert fires ]
v
[ Alertmanager :9093 ] --> route by severity --> [ SNS / receivers ]
```

9. Test Suite

Run: `pip install -e '[dev]' && pytest tests/unit/ -v && bash tests/terraform/validate.sh`
dev

9.1 Unit Tests

- test_prometheus_alertmanager.py: Prometheus YAML, 30d retention, alert rules, Alertmanager routing
- test_grafana_dashboards.py: Grafana JSON validity, gridPos, Athena dashboard SQL panels
- test_dashboard_validation.py: CloudWatch + Grafana dashboard structure validation
- test_lambda_report_generator.py: CSV/HTML reports, Athena query placeholders, handler mocks
- test_terraform_structure.py: Module files, env configs, no hardcoded secrets

9.2 Integration and E2E Tests

- test_infrastructure.py: ALB response, WAF protection, S3 config, Athena query files

- tests/e2e/run_e2e.py: End-to-end validation after deployment
- tests/terraform/validate.sh: terraform fmt, validate, plan for each environment
- tests/terraform/security_scan.sh: Static security checks on Terraform

9.3 Expected Test Coverage Areas

- Prometheus scrape config and 12 alert rules across security + infrastructure
- 5 Grafana dashboards including Athena log analytics with 13 SQL targets
- Lambda report generator with 6 Athena query templates
- Terraform modules: vpc, alb, waf, firehose, s3, glue, athena, lambda, monitoring, iam, kms, sns, cloudwatch

10. Deployment Quick Reference

```
cd terraform/environments/dev
terraform init && terraform apply
terraform output grafana_url
terraform output alb_dns_name

# Generate test traffic
python scripts/attack_simulation/simulate_sqli.py --url http://$ALB --count 20

# Verify Prometheus
curl http://<monitoring-ip>:9090/api/v1/query?query=up
curl http://<monitoring-ip>:9090/api/v1/query?query=aws_wafv2_blocked_requests_sum
```

11. Related Documentation

- docs/architecture/HLD.md - High Level Design
- docs/architecture/LLD.md - Low Level Design
- diagrams/aws-architecture.drawio - AWS icon architecture diagram
- docs/guides/grafana-athena-guide.md - Grafana Athena setup
- DEPLOY.md - Copy-paste deployment commands

Internal use - Security Operations Team